DOSSIER EJECUTIVO & TÉCNICO

CERTIFICACIÓN FINAL
100% PRODUCCIÓN READY

ATLAS Gym: Auditorías Escépticas & Plan de Remediación

Contexto Integral de Negocio, Vulnerabilidades Forenses y Resolución Certificada para Producción

PROYECTO & DOMINIO	MODELO DE OPERADORES	REPOSITORIOS & RAMA GIT	BATERÍA DE PRUEBAS
ATLAS Gym (Gimnasio Comercial AR)	**2 Hermanos Dueños + 1 Tablet Tótem**	**Back & Front:** `ramaLucas` **(Pushed)**	**44 JUnit | 151 Vitest | MySQL 8 OK**

1. Primera Auditoría Escéptica: "¿Por qué este proyecto no va a funcionar?"

Con el rol de un auditor Red-Team implacable analizando una entrega cercana a un cliente comercial real, se diagnosticó que el software funcionaba como una *"demo que se rompía sola"*, revelando 6 debilidades estructurales:

1.1. Arquitectura de "Doble Verdad" (Mock Data vs. MySQL)

Crítico

El frontend mutaba arrays en `localStorage` (`ALUMNOS_MOCK` , `PLANES_MOCK`). Si una petición REST fallaba silenciosamente o se cerraba la pestaña, los cobros y alumnos desaparecían del backend real, generando agujeros de caja y pérdida irrecuperable de dinero.

1.2. Usuario ADMIN Genérico y Falta de Trazabilidad

Crítico

Los dos titulares y la recepción operaban bajo una sola credencial compartida (`admin@atlasgym.com` / `admin123`). No existía trazabilidad de quién cobró, quién canceló un recibo o quién dio de baja a un alumno en el cajón de efectivo.

1.3. Tótem Ciego y Colapso en Hora Pico

Operación

El auto-checkin por DNI no cotejaba deudas con reglas de vencimiento reales ni respetaba cupos semanales. Ante un microcorte de red a las 19:00 hs, la tablet se congelaba y bloqueaba la puerta de entrada.

1.4. Colapso de Rendimiento: El Muro de los 800 Socios

Escalabilidad

Consultas JPA con problemas severos de N+1 (100 socios disparaban 100 queries a pagos y asistencias), ausencia de índices en MySQL y guardado de colecciones enteras en `localStorage` (rompiendo el tope de 5 MB del navegador).

1.5. El Motor Comercial no entendía la Cobranza Argentina

Finanzas

No contemplaba pagos multi-mes (trimestres o semestres), marcaba socios como morosos al día 2 del mes (ignorando la ventana de pago habitual del 1 al 10 en Argentina) y carecía de señas parciales.

1.6. Fricción en Sala de Musculación y Factor Humano

UX / Producto

Rutinas desvinculadas del perfil del socio, videoteca de técnica no optimizada y ausencia de feedback claro en las pantallas principales.

2. Segunda Auditoría Forense: Los 7 Agujeros de Operación Real y Red

Tras subsanar los incendios inmediatos de primera generación (N+1, Flyway base, estados elementales de cuotas), se ejecutó una segunda auditoría profunda sobre cómo se comporta el stack en el mundo físico. Se detectaron 7 vulnerabilidades de segunda capa:

HALLAZGO	VULNERABILIDAD TÉCNICA	IMPACTO EN EL GIMNASIO REAL	ARCHIVOS AFECTADOS
H-1 · RED	**Descalce /api y trampa de localhost:8080:** `NEXT_PUBLIC_API_URL` estática en `next build`.	Los dueños abren la app desde el celular por Wi-Fi (`192.168.x.x`), el celu busca backend en `localhost:8080` dentro de sí mismo, falla y abre un login fantasma offline.	`api-client.ts` `docker-compose.yml`
H-2 · ESCALA	**Polling sin filtro de fecha:** `refrescarAsistencias()` cada 5 s sin `?fecha=`.	A los 5 meses (35.000 fichajes), cada 5 segundos descarga megabytes de JSON, colapsa datos móviles y arroja `QuotaExceededError` en `localStorage`.	`AsistenciaController.java` `store.tsx`
H-3 · TÓTEM	**NEXT_PUBLIC_TOTEM_SECRET expuesta y modo offline ficticio:** Secreto en JS bundle público.	Cualquier socio lee el secreto en DevTools. Si se corta Internet 15 min, la tablet no tiene padrón real y rechaza socios. Sin cola Outbox, las asistencias offline se pierden.	`app/totem/page.tsx` `lib/totem-offline.ts`
H-4 · AUTH	**Anti-DoS global y contraseñas fijas:** Rate-limit por `identificador` sin ligar la IP del cliente.	Un tercero enviando 5 claves erróneas al mail del gimnasio bloquea a ambos dueños con `HTTP 429`. Socios nacen con clave = DNI sin forzar cambio.	`AuthService.java` `DataInitializer.java`
H-5 · CAJA	**Cobro duplicado, sin señas y DELETE físico:** Sin guardia de concurrencia para el mismo período.	Dos clics cobran doble la cuota. No permite entregas a cuenta ($10.000 de $30.000). Borrar pago ejecuta `DELETE` físico destruyendo la auditoría contable. Sin Arqueo diario.	`PagoService.java` `PagoController.java`
H-6 · DÍA 0	**Migración manual y falta de WhatsApp:** Sin importador masivo ni enlaces directos `wa.me`.	Cargar a mano 400 socios preexistentes antes de abrir lleva semanas. No hay avisos rápidos de deuda o credenciales por WhatsApp.	`alumnos/page.tsx` `finanzas/page.tsx`
H-7 · INFRA	**Backups solo en disco local y tráfico HTTP plano:** Sin copia externa ni proxy TLS.	Rotura de SSD o robo de la PC destruye todos los datos. Sin HTTPS, los JWT viajan en texto plano por el Wi-Fi abierto del local.	`docker-compose.yml` `scripts/backup-mysql.*`

3. Plan Maestro de Remediación (Las 7 Etapas Ideadas y Finalizadas)

Se ejecutó y validó una hoja de ruta rigurosa donde cada etapa neutralizó un hallazgo de raíz sin romper compatibilidad:

Etapa 1: Reverse Proxy Same-Origin (/backend-api) & Fin de Login Fantasma Verificado

Se creó `app/backend-api/[...path]/route.ts`. Todas las peticiones van al mismo origen de Next.js, que las enruta internamente hacia Spring Boot (`http://backend:8080`). Los celulares en Wi-Fi conectan de inmediato sin CORS ni conflictos de `localhost`. Se bloqueó el fallback `admin123` en producción.

Etapa 2: Polling Escalable por Fecha (?fecha=hoy) y Tope localStorage Verificado

El polling de 5 s en `/asistencias` solo consulta `?fecha=YYYY-MM-DD` realizando merge liviano en memoria. Carga histórica acotada a `?desde=&hasta=`. Caché local limitada estrictamente a 7 días / 500 filas en `atlas_asistencias_v2`.

Etapa 3: Tótem Resiliente, Caché Autorizada y Cola Outbox Idempotente Verificado

Se removió el secreto del bundle público. La tablet se vincula una única vez guardando el secreto en `localStorage` (`atlas_totem_device_secret`). Se creó `GET /padron-cache` para precargar datos mínimos y `POST /sync` con UUIDs (`clientEventId`) en Flyway `V2` para reintentar ingresos offline sin duplicados.

Etapa 4: Hardening de Identidad (Anti-DoS, 2 Cuentas Dueños y Clave Inicial) Verificado

Rate-limit por tupla `IP + usuario` (tope de 5 fallos consecutivos por usuario). Soporte para dos cuentas nominales independientes (`ATLAS_ADMIN_*` y `ATLAS_ADMIN2_*`) mediante Flyway `V3`. Forzado de cambio de clave en el primer inicio de sesión de alumnos y blanqueo 1-clic a DNI.

Etapa 5: Caja Real Argentina (Anti-Duplicado, Señas, Anulación y Arqueo Diario) Verificado

Guardia `HTTP 409 Conflict` si se cobra un período ya cubierto. Soporte de pagos parciales / señas (`EstadoPago.PARCIAL`) con liquidación de saldo. Anulación contable auditada (`EstadoPago.ANULADO` con motivo y titular operante) en lugar de `DELETE` destructivo. Panel interactivo de **Arqueo de Caja del Día** desglosado por método y operador (Flyway `V4`).

Etapa 6: Kit de Día Cero (Importador Masivo CSV y WhatsApp 1-Clic) Verificado

Endpoint transaccional `POST /api/alumnos/importar` con previsualización en UI, matching de planes tolerante a tildes/mayúsculas y seeding del último mes pago. Botones WhatsApp 1-clic (`wa.me`) con normalización de números argentinos (`+54 9` , sin prefijos `0` ni `15`) para credenciales y avisos de deuda.

Etapa 7: Infraestructura Blindada (Caddy TLS, Backup Offsite y Restore) Verificado

Servicio Caddy en `docker-compose.yml` con TLS automático y cabeceras seguras. Scripts de backup (`backup-mysql.*`) con validación gzip y hooks offsite hacia carpeta sincronizada o nube (`rclone`). Scripts de restauración (`restore-mysql.*`) con snapshot de seguridad previo automático y búsqueda autónoma de binarios MySQL en Windows.

4. Certificación Final de Verificación y Estado del Repositorio

Batería de Pruebas de Punta a Punta (100% Passing)

Certificado

- **Backend (Spring Boot 3.4.3 / JUnit 5): 44 / 44 tests PASS** (`BUILD SUCCESS`).
- **Esquema & Migraciones Flyway:** `FlywayEsquemaValidacionTest` validó las versiones V1, V2, V3 y V4 contra Hibernate con `ddl-auto=validate` con 0 discrepancias de esquema.
- **Frontend (Vitest 5.0): 151 / 151 tests PASS** en 19 archivos de prueba unitaria y de componentes.
- **TypeScript Estricto:** `npx tsc --noEmit` finalizó con **0 errores de tipado**.
- **Compilación Next.js Turbopack:** `next build` compiló exitosamente las 13 rutas de la aplicación en producción.
- **Smoke Test E2E contra MySQL 8.0 Real:** Se corrió un guion integral de 30 operaciones consecutivas (autenticación nominal de titulares, prevención 409 de cobro duplicado, seña parcial, anulación auditada, arqueo contable, sincronización offline del tótem e importación masiva CSV). **30/30 aserciones pasaron en verde.**

Sincronización en GitHub y Memoria para Claude Code

Git & Context

- **Backend (`atlasgym_back`):** Rama `ramaLucas` pusheada y sincronizada con `origin/ramaLucas` (commit `3cdd44d`). Working tree limpio.
- **Frontend (`atlasgym_front`):** Rama `ramaLucas` pusheada y sincronizada con `origin/ramaLucas` y `mi-fork/ramaLucas` (commit `d8d23ff`). Working tree limpio.
- **Archivos Maestros `CLAUDE.md` :** Incorporados en la raíz de ambos repositorios, describiendo con exactitud las reglas del gimnasio real (2 hermanos dueños, cuotas del 1 al 10, alerta semanal del tótem, arqueo contable y comandos operativos).

COMPONENTE	TECNOLOGÍA	COMANDO DE TEST	COMANDO DE COMPILACIÓN / RUN
Backend	Spring Boot 3.4.3 + MySQL 8 + Flyway	`.\mvnw.cmd test`	`.\mvnw.cmd -DskipTests package`
Frontend	Next.js 16.3 + React 19 + Tailwind 4	`npx vitest run`	`npm run build`
Reverse Proxy	Caddy 2 Alpine + TLS automático	`docker compose config`	`docker compose up -d --build`
Backups	PowerShell / Bash + Gzip + Offsite	`.\scripts□ackup-mysql.ps1`	`.\scripts estore-mysql.ps1 -Force`